

A1 Classification des incidents P1-P4 et SLA

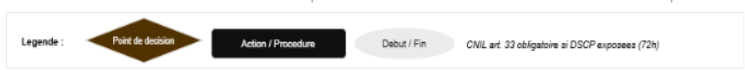
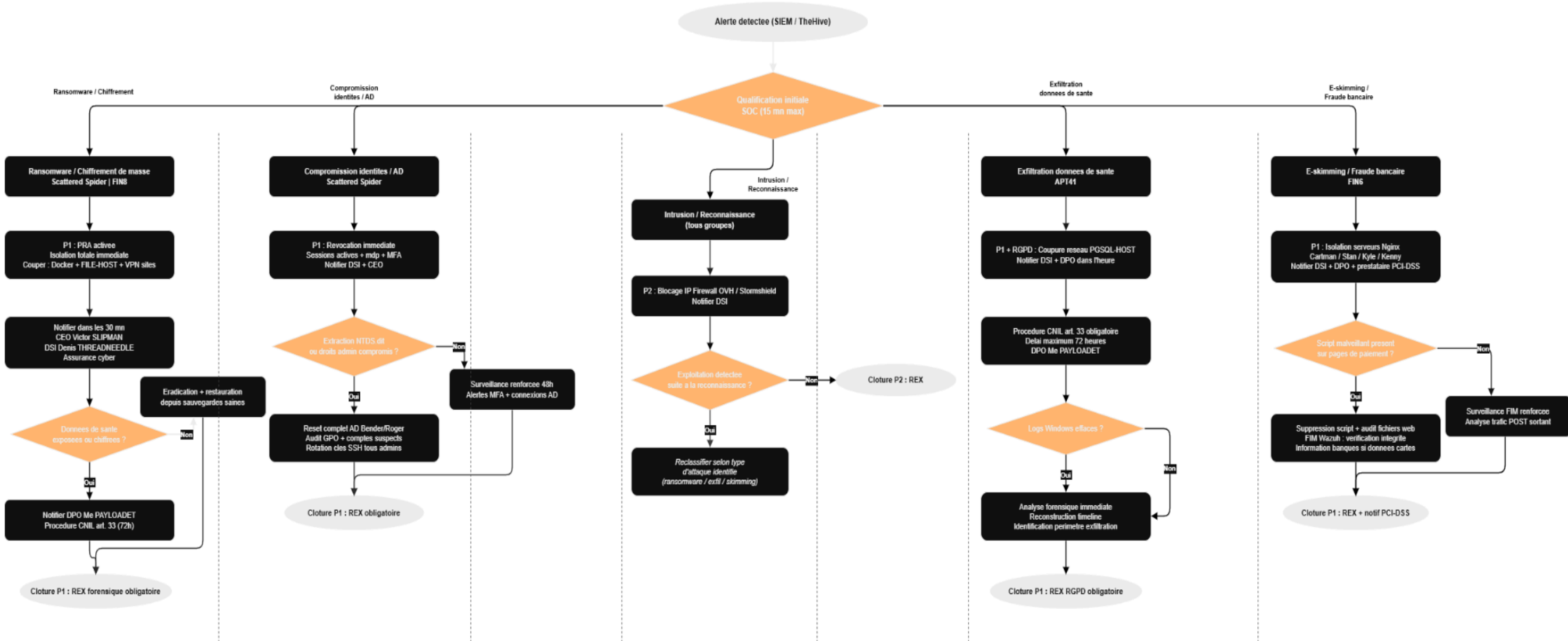
Niveau	Exemples SL1PCONNECT	SLA réponse	SLA résolution	CNIL art.33	Escalade
P1 CRITIQUE	SQLi BRIEF, exfiltration PGSQL-HOST, ransomware, compromission BOXER avec DSCP	1 heure	4 heures	Obligatoire si DSCP	DSI + DPO + CEO
P2 ÉLEVÉ	Scan ports Docker, compromission compte admin, secrets exposés, Grafana creds défaut	4 heures	8 heures	A évaluer avec DPO	DSI
P3 MOYEN	CVE Trivy, brute-force échoué, anomalie trafic, logs absents	1 jour	3 jours	Non requis	Consultant SOC
P4 FAIBLE	Rotation cles SSH manquante, patch en retard, mdp non conforme	3 jours	1 semaine	Non requis	Rapport mensuel

A2 Matrice RACI | R = Responsable A = Accountable C = Consulte I = Informe

Phase	SOC	DSI	DPO	CEO	Admin sys	Outil
Detection / Alerting	R	I	I	I	I	SIEM / TheHive
Qualification / Triage	R	C	I	I	I	TheHive
Endiguement	C	R	I	I	C	Firewall OVH / SSH
Notification CNIL (si DSCP)	C	I	R	A	I	Teleservice CNIL
Eradication technique	C	R	I	I	R	SSH / Docker / AD
Retour à la normale	R	C	I	I	C	TheHive / Tests
Clôture / REX	R	A	C	I	I	TheHive / Word

A3 Arbre de décision opérationnel

SL1PCONNECT SAS : Arbre de decision SOC | Processus macro de reponse aux incidents



A4 Règles de corrélation SIEM (Wazuh)

Regle ID	P	Condition de déclenchement	Source log	Playbook	ISO 27001
SQLI-BRIEF-001	P1	Pattern SQL dans POST sur BRIEF :8081 (UNION / SELECT / DROP)	Apache BRIEF / Nginx BOXER-HOST	PB-01	A.5.26 / A.8.25
BRUTE-ADMIN-001	P1	Plus de 10 échecs auth en 5mn sur BRIEF, WATCH ou AD (Event 4625)	Apache / Grafana / Windows Event	PB-02	A.5.15 / A.5.17
PORTSCAN-OVH-001	P2	Plus de 500 SYN/60s depuis même IP vers DMZ 10.0.1.0/24	Firewall OVH / Wazuh Network	PB-03	A.8.16 / A.8.20
EXFIL-PGSQL-001	P1	Transfert supérieur à 10MB depuis PGSQL-HOST vers IP externe en moins de 5mn	PostgreSQL / Firewall OVH	PB-04	A.5.26 / A.5.34
RANSOM-FILE-001	P1	Création massive *.locked en moins de 2mn ou CPU PGSQL supérieur à 95%	Wazuh FIM / Sysmon	PB-05	A.5.30 / A.8.13
API-NOAUTH-001	P2	Accès /api/* sur BOXER :8080 sans header Authorization	Nginx BOXER-HOST	PB-01 / PB-03	A.8.20 / A.8.25
DOCKER-ROOT-001	P2	Process root dans conteneur avec exec vers PGSQL-HOST ou FILE-HOST	Wazuh Docker / Auditd	PB-01 / PB-05	A.8.25 / A.8.9
GRAFANA-DEFAULT-001	P2	Auth admin/admin réussie sur WATCH :9090	Grafana access.log	PB-03	A.5.15 / A.8.16

A5 Ticket TheHive - exemple type (PB-01 SQLi BRIEF)

Champ	Valeur (exemple PB-01 SQLi BRIEF)
Titre	SQLi détectée sur BRIEF :8081 - Possible exfiltration PGSQL-HOST
Severity	Critical (P1)
Tags	SQLi, BRIEF, PGSQL-HOST, RGPD, DSCP, OVH
SLA réponse	1 heure
SLA résolution	4 heures
Observables	IP source, payload SQLi, session cookie, volume transfert PGSQL-HOST
Notifier	DSI Denis THREADNEEDLE DPO Me PAYLOADET (si DSCP) CEO Victor SLIPMAN
ISO 27001	A.5.26 Réponse aux incidents / A.8.25 Securite dev / A.5.34 Vie privée

A6 Playbooks synthétiques - Kill Chain et réponse (PB-01 a PB-05)

Chaque ligne couvre les phases clés de la Cyber Kill Chain. Le détail complet de chaque playbook est disponible dans le document de gestion des incidents v3.

Playbook	Criticité	Reconnaissance	Delivery / Exploitation	Actions finales	IOC / Signal SIEM	Réponse T+0 a T+1h	CNIL art.33
PB-01SQLi BRIEF :8081	P1	T1595 - Scan ports OVH (8080-9090)	T1190 - Payload SQLi OR 1=1 sur BRIEF :8081	T1005 - Exfiltration donnees de sante PGSQL-HOST	HTTP 200 apres SQLi, transfert supérieur à 10MB PGSQL-HOST	Blocage IP OVH + docker stop brief + snapshot DOCKER-HOST	Obligatoire si DSCP
PB-02 Compromission compte admin	P1	T1589 - OSINT comptes admin SL1PCONNECT	T1110 - Brute force BRIEF :8081 / WATCH :9090	T1003 - Dump credentials AD, mouvement latéral PGSQL	Plus de 10 échecs puis HTTP 200 depuis IP inconnue	Revocation session + reset mdp + MFA + notification DSI/CEO	A evaluer
PB-03Scan ports Docker	P2	T1595.001 - Nmap/Masscan DMZ OVH 10.0.1.0/24	T1078 - Auth admin/admin Grafana WATCH :9090	Pivot vers SQLi ou brute force selon vecteur identifié	Plus de 500 SYN/60s, session Grafana IP inconnue	Blocage IP OVH + reset mdp Grafana + restriction port 9090	Non requis
PB-04 Fuite donnees de sante	P1 + CNIL	T1595 - Sonde port 5432 PGSQL-HOST	T1213 - SELECT massifs tables donnees sante	T1048 - Dump PostgreSQL via HTTPS vers C2	Transfert superieur a 10MB depuis 10.0.1.30 vers IP externe	Coupure réseau PGSQL-HOST + DPO notifie + CNIL art.33 active	Obligatoire (72h)
PB-05 Ransomware	P1 - PRA	T1595 - Scan ports 445 / 3389 / 22	T1566/T1190 - Phishing DSI ou SQLi BRIEF comme vecteur	T1486 - Chiffrement FILE-HOST + PGSQL-HOST + postes Nice	Fichiers *.locked en masse, ransom note, CPU PGSQL supérieur à 95%	Isolation totale en 5mn + PRA + CEO notifie + assurance cyber	Si DSCP chiffrées

A7 Template REX (obligatoire P1/P2)

Section REX	Contenu attendu
Identifiant	INC-YYYYMMDD-XXX Criticite P1/P2 Statut : CLOS
Chronologie	Timeline T+0 detection / endiguement / eradication / cloture
Cause racine	Analyse 5 Pourquoi : technique, humaine, organisationnelle
Impact	Donnees exposees, nombre de personnes, impact métier, RGPD/HDS
SLA respectés	SLA réponse et résolution tenus - sinon raisons
Leçons apprises	Correctifs court terme + recommandations long terme + MAJ playbook
Délai rédaction	P1 : moins de 5 jours ouvrables P2 : moins de 15 jours
Validation	Consultant SOC DSI Denis THREADNEEDLE DPO (si RGPD)

A8 KPIs de performance SOC

KPI	Cible	Mesure via
MTTD (temps moyen detection)	Inf. a 15mn pour P1/P2	Dashboard Kibana
MTTR (temps moyen reponse)	Inf. a 1h P1 / inf. a 4h P2	TheHive SLA tracker
Taux SLA respectés	Supérieur à 90%	Rapport mensuel TheHive
Taux faux positifs SIEM	Inférieur à 20%	Wazuh / Kibana
REX produits dans les délais	Supérieur à 95%	Registre REX

A9 Mapping ISO 27001:2022 - contrôles couverts par le SOC

Contrôle ISO 27001	Libellé	Section document
A.5.24	Planification et préparation de la gestion des incidents	Sections 1, 2, 5
A.5.25	Evaluation et décision sur les événements de sécurité	Section 2 (classification P1-P4)
A.5.26	Réponse aux incidents de sécurité de l'information	Sections 5 et 8 (playbooks)
A.5.27	Retour d'expérience des incidents	Section 11 (REX)
A.5.34	Vie privée et protection des données personnelles	Section 9 (CNIL art.33)
A.8.15 / A.8.16	Journalisation et activités de surveillance	Section 10 (SIEM - règles)
A.5.30	Préparation TIC pour la continuité (PRA)	Section 8 - PB-05 Ransomware